Medoq : Cahier des charges technique (consultation)

Oct 29, 2026 · @Amadou NIANG

Document de consultation destiné aux développeurs invités à chiffrer la phase 1. Il contient tout ce qui sert à chiffrer : chantiers, règles métier, critères de recette et conditions. La version complète, avec l'état détaillé du code et le périmètre de l'audit de sécurité, est remise au seul développeur retenu, après signature d'un accord de confidentialité. Porteur du projet : Amadou Niang, niangamadou394@gmail.com, +33 6 17 56 63 42.

1. Mission et produit

1.1 Mission

Permettre à un habitant de Dakar de savoir, en moins d'une minute et depuis son téléphone, dans quelle pharmacie proche un médicament est effectivement disponible, de le faire mettre de côté et d'aller le retirer. La valeur n'est ni le paiement ni la livraison : elle est dans l'information fiable de disponibilité.

1.2 Le parcours de la phase 1

1. Le patient cherche un médicament par nom commercial ou par DCI.
2. Le système affiche les pharmacies dans un rayon de 10 km qui déclarent la référence disponible, triées par distance, avec un indicateur (disponible / stock faible) et **jamais la quantité exacte**.
3. Le patient réserve. Il reçoit une référence `MRX-2026-000123` valable 2 heures.
4. La pharmacie reçoit l'alerte en temps réel sur sa tablette et **acquitte** la mise de côté.
5. Le patient se présente, donne sa référence, paie au comptoir, repart avec sa boîte.
6. Le pharmacien marque le retrait comme effectué sur la tablette.

Si la pharmacie n'acquitte pas l'alerte dans les 30 minutes, la réservation est annulée et le patient prévenu.

1.3 Modèle économique

Le revenu de Medoq vient de l'abonnement mensuel des pharmacies. Aucun paiement en ligne et aucune commission en phase 1 : l'argent ne transite jamais par Medoq. Le classement des résultats n'est jamais vendu.

1.4 Hors périmètre de la phase 1

- Paiement en ligne (Wave, Orange Money, tout prestataire) : phase 2.
- Livraison à domicile et coursiers.
- Application mobile native Android ou iOS : l'application web (PWA) suffit.
- Tableau de bord séparé : tout passe par l'application web, avec des vues par rôle.
- Gestion de l'ordonnance au-delà du marquage et du blocage (C8).
- Toute ville autre que Dakar.
- Tout conseil, posologie ou interaction médicamenteuse : Medoq informe sur la disponibilité, jamais sur l'usage.

2. Contexte technique

Le produit existe et tourne en production. La phase 1 consiste à le fiabiliser et à le compléter, pas à le réécrire.

2.1 Technologie en place

- API REST **Node.js 22 / Express 4 / PostgreSQL**, hébergée sur **Render**.
- Application web progressive (PWA) en un seul fichier HTML d'environ 120 Ko, servie par l'API, qui sert de client unique.
- Authentification par JWT avec jetons de rafraîchissement ; SMS par Africa's Talking ; courriels par Nodemailer.
- Les autres prototypes front (tableau de bord Angular, build Flutter) sont abandonnés ou gelés.

2.2 Ce qu'il faut savoir pour chiffrer

- **Le schéma réel de la base de production n'est pas connu avec certitude.** Il est aujourd'hui créé au démarrage du serveur, sans outil de migration. Le chantier C0 commence par le constater ; il peut révéler des écarts qui allongent son estimation.
- Aucun test automatisé ni intégration continue n'existe.
- Certains types de colonnes sont hérités d'une ancienne version SQLite (dates en texte, booléens en entiers).
- Le paiement en ligne présent dans le code est une simulation, hors périmètre.
- **Audit de sécurité à réaliser au chantier C1 ; périmètre détaillé communiqué après signature.**

3. Décisions d'architecture arrêtées

Ces décisions sont arrêtées : ce ne sont pas des options à rediscuter en cours de chantier.

3.1 Une seule interface web, avec des vues par rôle

Décision : la PWA reste le client unique, avec trois vues selon le rôle : patient, pharmacien, administrateur.

Raison : deux applications front, c'est deux chaînes de construction et deux risques de désynchronisation avec l'API, pour une seule ville et quelques dizaines d'officines. Le fichier unique se charge d'un coup sur un Android d'entrée de gamme en 3G.

À implémenter : un service worker (cache, fonctionnement partiel hors ligne), un tampon de version dans le build, et un contrôle de version d'API au démarrage du client qui force le rechargement si le serveur a avancé.

3.2 Server-Sent Events, pas WebSocket

Décision : l'alerte temps réel vers la tablette utilise SSE.

Raison : le besoin va uniquement du serveur vers la tablette. SSE tient sur HTTP simple, se reconnecte seul, traverse les proxys et ne demande aucune dépendance. Le protocole d'upgrade WebSocket pose des problèmes sur certains réseaux mobiles sénégalais.

Multi-instance : `LISTEN` / `NOTIFY` de PostgreSQL sert de bus entre instances, sans Redis.

3.3 Pas de paiement en ligne en phase 1

Décision : paiement au comptoir, commission à 0 %, aucun prestataire intégré.

Raison : dès que l'argent transite par Medoq arrivent le reversement aux officines, la réconciliation comptable et le statut réglementaire de la collecte de fonds pour compte de tiers en zone UEMOA. Aucun n'apporte un patient de plus en phase 1.

En phase 2 : Wave d'abord (webhook signé HMAC-SHA256), Orange Money ensuite (2 à 4 semaines d'activation commerçant).

3.4 La pharmacie est le commerçant, pas Medoq

Décision : la vente est conclue entre le patient et l'officine ; Medoq est un intermédiaire d'information. Les CGU et le contrat pharmacie le disent explicitement.

Raison : la dispensation de médicaments est un monopole pharmaceutique encadré.

3.5 Un parc de tablettes en mode kiosque

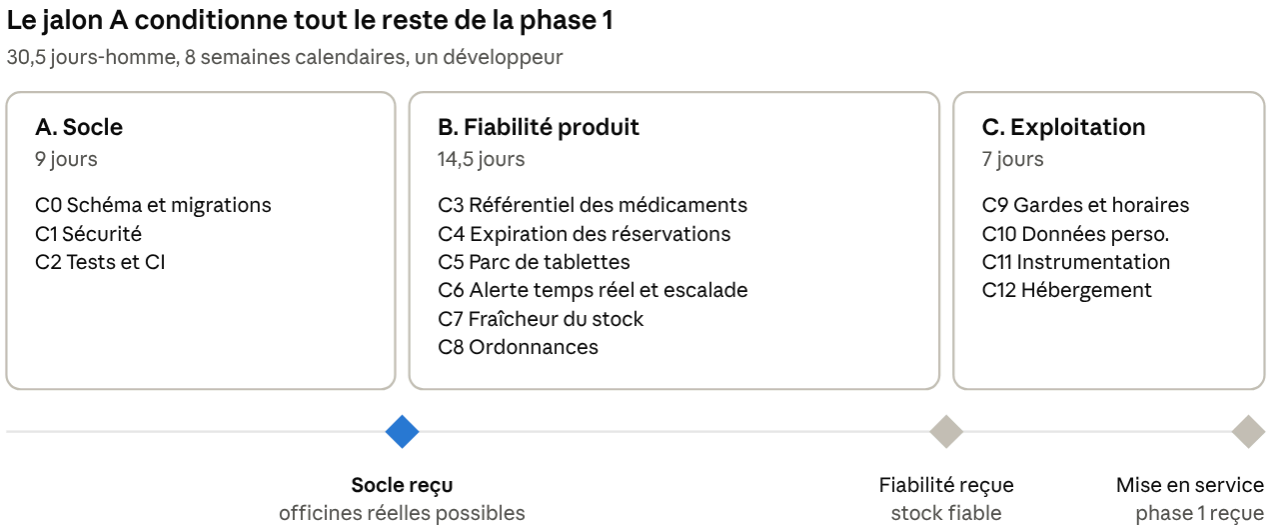
Décision : chaque officine reçoit une tablette Android en mode kiosque, application épinglée, qui ne sert qu'à Medoq.

Raison : si le pharmacien doit ouvrir un navigateur et se souvenir d'un mot de passe entre deux clients, il ne le fera pas, et le stock affiché sera faux. Une tablette posée sur le comptoir, qui sonne quand une réservation arrive, change la nature du problème.

Obligation créée : une tablette déchargée laisse une officine affichée comme disponible alors que personne ne répondra. D'où le chantier C5 et la table `devices`.

4. Phase 1 : chantiers

Treize chantiers, C0 à C12, en trois jalons pour 30,5 jours-homme, soit 8 semaines calendaires pour un développeur seul. L'ordre des jalons est imposé : A conditionne tout le reste, B conditionne la valeur perçue du produit.



phase 1 · 3 jalons, 13 chantiers

Chaque jalon est reçu en production avant que le suivant commence ; le paiement suit ces passages.

Réf.	Chantier	Jalon	Jours	Bloquant
C0	Schéma réel et migrations	A	3	oui
C1	Sécurité	A	3	oui
C2	Tests et intégration continue	A	3	oui
C3	Référentiel des médicaments	B	4	

Réf.	Chantier	Jalon	Jours	Bloquant
C4	Expiration des réservations	B	2	oui
C5	Parc de tablettes et supervision	B	2	
C6	Alerte temps réel et escalade	B	3	oui
C7	Fraîcheur du stock	B	2	
C8	Médicaments sur ordonnance	B	1,5	
C9	Pharmacies de garde et horaires	C	3	oui
C10	Données personnelles	C	1,5	oui
C11	Instrumentation du tunnel	C	1	
C12	Hébergement, sauvegardes, supervision	C	1,5	oui
	Total		**30,5**	

Les jours sont l'estimation du porteur de projet ; le candidat les confirme ou les corrige dans son devis.

Jalon A : Socle (9 jours)

Objectif : pouvoir modifier la base et le code sans casser la production. Rien du jalon B ne commence avant la fin du jalon A.

C0. Schéma réel et migrations (3 j, bloquant). Premier jour, première tâche.

- Extraire le schéma de production (`pg_dump --schema-only`) et le comparer ligne à ligne au code qui le crée ; documenter chaque écart dans `docs/schema-reel.md` .
- Installer node-pg-migrate. Migration n° 1 = le schéma réellement constaté, pas le schéma théorique.
- Le serveur ne modifie plus jamais le schéma au démarrage.
- Migrations de dette, une par changement, réversibles : dates en `TIMESTAMPTZ` , booléens en `BOOLEAN` , montants en FCFA entiers.
- Le déploiement exécute les migrations avant de démarrer l'application et échoue bruyamment en cas d'erreur.
- *Fin :* `npm run migrate` sur une base vide produit exactement le schéma de production, diff vide.

C1. Sécurité (3 j, bloquant). Audit de sécurité de l'API et durcissement. Le périmètre détaillé de l'audit est communiqué après signature. Le chantier couvre au minimum :

- en-têtes de sécurité HTTP et limitation des requêtes, renforcée sur l'authentification, l'envoi de SMS et la recherche ;
- contrôle d'autorisation sur chaque route portant un identifiant (IDOR), avec un test automatisé par route ;
- rotation des jetons de rafraîchissement avec détection de réutilisation et révocation de famille ;
- stockage sûr des secrets et des codes à usage unique ; vérification au démarrage des paramètres de sécurité obligatoires en production ;
- création du premier administrateur par un script d'exploitation, jamais par une route HTTP ;
- mot de passe de 10 caractères minimum pour les comptes pharmacie et administrateur ;
- en-tête `Idempotency-Key` sur la création de réservation ;
- journal d'audit des modifications de stock et des annulations, avec l'appareil d'origine.

C2. Tests et intégration continue (3 j, bloquant).

- Jest ou Vitest, avec Supertest pour les routes.
- Couverture obligatoire : réservation concurrente, expiration, calcul de distance, autorisation par rôle, machine à états d'une réservation.
- GitHub Actions : installation, migrations sur une base jetable, tests ; un échec bloque la fusion.
- Sentry sur l'API et sur la PWA.

Jalon B : Fiabilité produit (14,5 jours)

Objectif unique : qu'un patient qui se déplace trouve sa boîte. Un patient déçu une fois ne revient pas.

C3. Référentiel des médicaments (4 j). À faire avant la deuxième pharmacie, pas après la dixième.

- Table de références canoniques (DCI, dosage, forme galénique), basée sur la liste nationale des médicaments essentiels.
- Table d'alias de noms commerciaux pointant vers la référence canonique.
- Le stock d'une officine se rattache à une référence canonique, jamais à du texte libre.
- L'import CSV devient un rapprochement validé par un humain : le système propose, l'opérateur confirme ou corrige.
- Recherche par nom commercial et par DCI, tolérante aux fautes de frappe.

C4. Expiration des réservations (2 j, bloquant).

- Une réservation non retirée expire au bout de 2 heures et le stock est rendu.
- Tâche périodique avec `SELECT ... FOR UPDATE SKIP LOCKED`, sûre si deux instances tournent en même temps.
- SMS au patient à l'expiration, retrait de l'alerte sur la tablette.
- Fuseau `Africa/Dakar` (UTC+0, sans heure d'été), dates en `TIMESTAMPTZ`.

C5. Parc de tablettes et supervision (2 j).

- Table `devices` : officine, numéro de série, dernière connexion, version applicative, niveau de batterie.
- Battement de cœur toutes les 60 secondes.
- Officine retirée de la recherche après 30 minutes hors ligne.
- Vue d'exploitation : tablettes, dernière connexion, version.
- Mode kiosque Android : application épinglée, mise à jour à distance, procédure de remise en service documentée.

C6. Alerte temps réel et escalade (3 j, bloquant).

- SSE vers la tablette, reconnexion automatique et rattrapage des événements manqués.
- `LISTEN` / `NOTIFY` PostgreSQL entre instances.
- Signal sonore et visuel persistant jusqu'à acquittement.
- Escalade : SMS au pharmacien titulaire à 10 minutes sans acquittement ; à 30 minutes, annulation, SMS au patient et signalement dans la vue d'exploitation.

C7. Fraîcheur du stock (2 j).

- Date de dernière déclaration sur chaque ligne de stock.
- Pas de réservation sur une ligne déclarée il y a plus de 48 heures : la référence reste visible avec « à confirmer avec la pharmacie » et son téléphone, bouton inactif.
- Chaque matin, la tablette propose les 20 références les plus demandées à confirmer ou corriger en bloc.
- Décrémentation atomique `UPDATE ... WHERE quantity >= $1` avec contrôle du nombre de lignes affectées.
- Le patient ne voit jamais la quantité exacte : disponible, stock faible (5 unités ou moins) ou indisponible, y compris dans les réponses de l'API et les messages d'erreur.

C8. Médicaments sur ordonnance (1,5 j).

- Drapeau « sur ordonnance » sur la référence canonique.
- Avertissement à la réservation : délivrance soumise à la présentation de l'ordonnance, le pharmacien peut refuser.
- Aucun stockage, aucune photo, aucun téléversement d'ordonnance.

Jalon C : Exploitation (7 jours)

Objectif : faire tourner le service tous les jours, le mesurer et le défendre devant une autorité.

C9. Pharmacies de garde et horaires (3 j, bloquant).

- Horaires par officine et par jour de la semaine.
- Calendrier des gardes, avec import et correction manuelle.
- Une officine fermée n'est pas réservable.
- Filtres « ouvert maintenant » et « de garde » dans la recherche.
- Distance haversine calculée en SQL, rayon de 10 km, tri exclusivement par distance.

C10. Données personnelles (1,5 j, bloquant).

- Loi sénégalaise n° 2008-12 et déclaration à la CDP.
- Politique de confidentialité et CGU accessibles depuis la PWA.
- Durée de conservation appliquée par une tâche de purge.
- Les journaux n'associent jamais un numéro de téléphone à une recherche de molécule : anonymisation à l'écriture.
- Export et suppression de compte sur demande.

C11. Instrumentation du tunnel (1 j).

- Événements : recherche, recherche sans résultat, réservation créée, acquittée, retirée, expirée, annulée.
- Taux de retrait réussi, délai médian d'acquittement par officine, taux de recherche sans résultat avec les molécules introuvables.

C12. Hébergement, sauvegardes, supervision (1,5 j, bloquant).

- Hébergement et base de données en palier payant, sans mise en veille : l'alerte temps réel n'y survit pas.
- Sauvegardes quotidiennes avec une restauration réellement testée.
- Supervision de disponibilité avec alerte, tableau des erreurs Sentry.
- `.env.example` complet et README : installation, migrations, tests, déploiement.

5. Phase 2 : après la mise en service

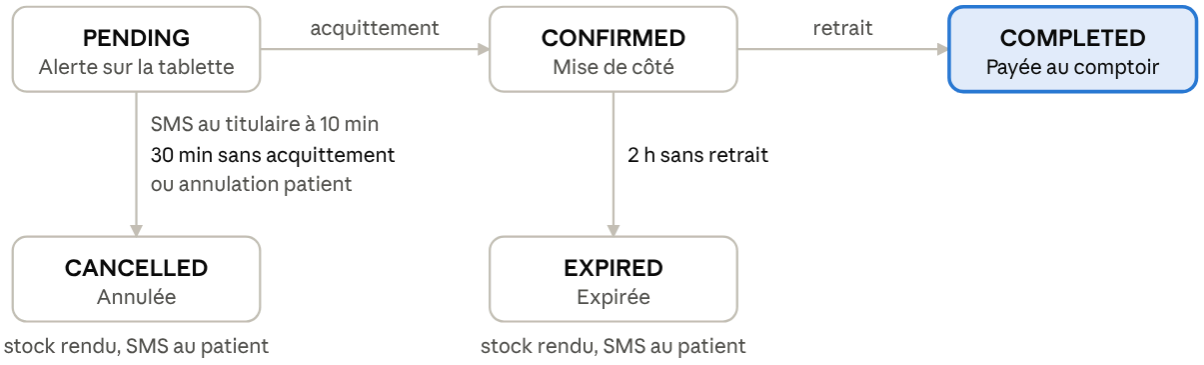
Hors commande initiale. À n'ouvrir qu'une fois la phase 1 reçue et une dizaine d'officines réellement actives, dans l'ordre ci-dessous.

Chantier	Estimation	Condition de déclenchement
Console d'administration complète	2 j	Dès que l'exploitation quotidienne le demande
Tableau de bord pharmacie (statistiques officine)	2 j	Argument de vente de l'abonnement payant
Paiement en ligne Wave	5 à 6 j	Quand le prépaiement devient une demande patient
Orange Money	3 j + 2 à 4 semaines d'activation	Après Wave, jamais en parallèle
Livraison à domicile	à chiffrer	Cadre réglementaire clair au préalable
Extension hors Dakar	à chiffrer	Après saturation de Dakar

6. Règles métier

6.1 Réservation

Une réservation non acquittée ou non retirée rend toujours son stock



cycle de vie d'une réservation en phase 1 · 5 statuts

Les noms de statuts sont une proposition, à confirmer au chantier C0 : le cycle en place aujourd'hui en diffère et devra y être ramené. Le patient peut annuler tant que la réservation n'est pas retirée.

Règle	Valeur	Variable
Durée de validité d'une réservation	2 heures	`RESERVATION_TTL_HOURS`
Délai d'acquittement par la pharmacie	30 minutes	`PHARMACY_ACK_TIMEOUT_MINUTES`
Escalade SMS au titulaire	10 minutes	`PHARMACY_ESCALATION_MINUTES`
Réservations actives simultanées par patient	2	`MAX_ACTIVE_RESERVATIONS_PER_USER`
Fraîcheur de stock requise pour réserver	48 heures	`STOCK_FRESHNESS_HOURS`
Format de référence	`MRX-AAAA-000123`	
Rayon de recherche	10 km (haversine)	`SEARCH_RADIUS_KM`
Seuil d'alerte de stock faible	5 unités	`LOW_STOCK_THRESHOLD`

Pourquoi 2 réservations actives au maximum : sans prépaiement, réserver ne coûte rien au patient. Sans limite, un seul compte peut immobiliser le stock de plusieurs officines ; cette limite est la seule protection de l'officine.

6.2 Argent

- Commission : 0 %. Livraison : inactive (hors périmètre).
- Le paiement se fait au comptoir. Le statut de paiement passe à `COMPLETED` quand le pharmacien marque le retrait sur la tablette.
- Aucun flux financier ne traverse Medoq en phase 1.

6.3 Comptes et authentification

Règle	Valeur
Validité d'un code OTP	10 minutes
Verrouillage après échecs de connexion	5 échecs, 15 minutes
Mot de passe minimal (pharmacie, admin)	10 caractères
Stockage des codes OTP	hachés

Règle	Valeur
Rotation des jetons de rafraîchissement	obligatoire, avec détection de réutilisation

6.4 Officines

- Une officine n'est visible dans la recherche que si elle est active (validée par un administrateur).
- Une officine dont la tablette est hors ligne depuis plus de 30 minutes est retirée de la recherche, même active.
- Une officine fermée selon ses horaires n'est pas réservable. Elle peut rester visible avec son horaire d'ouverture et, si elle est de garde, avec la mention de garde.
- Le classement des résultats est exclusivement géographique : jamais influencé par l'abonnement, le prix ou une contrepartie commerciale.

7. Qualité, sécurité, conformité

7.1 Qualité logicielle

- Toute modification du schéma passe par une migration versionnée et réversible ; le serveur ne modifie plus jamais le schéma au démarrage.
- Intégration continue obligatoire : aucune fusion sur la branche principale si les tests échouent.
- Couverture impérative : réservation concurrente, expiration, autorisation par rôle, machine à états des réservations.
- Journalisation structurée, sans donnée de santé nominative.
- Sentry sur l'API et sur la PWA, avec alerte sur nouvelle erreur.

7.2 Sécurité

- En-têtes de sécurité et limitation des requêtes, renforcée sur l'authentification et la recherche.
- Contrôle d'autorisation sur chaque route portant un identifiant, testé automatiquement.
- Codes à usage unique hachés ; mot de passe de 10 caractères minimum pour les comptes professionnels ; rotation des jetons avec révocation de famille en cas de réutilisation.
- `Idempotency-Key` sur la création de réservation.
- Journal d'audit des modifications de stock et des annulations, avec l'appareil d'origine.

- Secrets uniquement en variables d'environnement, jamais dans le dépôt ; rotation documentée.
- Le serveur refuse de démarrer en production si un paramètre de sécurité obligatoire manque ou est désactivé.

7.3 Conformité

- Loi n° 2008-12 sur les données personnelles ; déclaration à la CDP avant la mise en service.
- Les recherches de médicaments d'un utilisateur identifié sont des données de santé : anonymisées dans les journaux, conservation limitée et appliquée techniquement.
- Monopole pharmaceutique : Medoq n'est pas vendeur et ne dispense pas. Les CGU et le contrat pharmacie le disent.
- Médicaments sur ordonnance : signalés dans l'interface, délivrance conditionnée à l'ordonnance au comptoir, aucun stockage d'ordonnance.
- Prix administrés : Medoq n'affiche ni ne modifie de prix public en phase 1 ; le prix est celui du comptoir.
- Aucun conseil, aucune posologie, aucune interaction médicamenteuse.

8. Critères de recette

8.1 Recette technique

Chaque critère est démontré en production, pas en local.

- [ ] `npm run migrate` sur une base vide produit exactement le schéma de production ; le diff avec `pg_dump --schema-only` est vide.
- [ ] Le serveur démarre sans créer ni modifier aucune table.
- [ ] Deux réservations simultanées sur la dernière boîte : une seule réussit, le stock n'est jamais négatif.
- [ ] Une réservation non retirée disparaît et rend le stock au bout de 2 heures ; le patient reçoit un SMS.
- [ ] Une réservation non acquittée déclenche un SMS au titulaire à 10 minutes et est annulée à 30 minutes.
- [ ] Une tablette débranchée fait disparaître l'officine de la recherche en moins de 30 minutes, puis réapparaître à la remise sous tension.
- [ ] Une ligne de stock non confirmée depuis plus de 48 heures n'est plus réservable.
- [ ] Un patient ne peut ni lire ni modifier la réservation d'un autre en changeant l'identifiant dans l'URL ; un pharmacien ne voit que son officine. Testé automatiquement.

- [ ] Une recherche à 23 h ne propose comme réservables que des officines ouvertes ou de garde.
- [ ] Un double appui avec la même `Idempotency-Key` crée une seule réservation.
- [ ] Une restauration de sauvegarde est effectuée et vérifiée devant témoin.
- [ ] La suite de tests passe en intégration continue, et un test cassé bloque la fusion.

8.2 Indicateurs produit

Disponibles dès le jour de la mise en service (chantier C11).

Indicateur	Définition	Cible initiale
Taux de retrait réussi	réservations retirées / réservations créées	plus de 80 %
Délai médian d'acquittement	temps entre l'alerte et la confirmation de l'officine	moins de 10 minutes
Taux de recherche sans résultat	recherches sans officine / recherches totales	moins de 30 %
Réservations par officine et par jour	moyenne sur 30 jours	4 à 5
Disponibilité des tablettes	part du temps en ligne aux heures d'ouverture	plus de 95 %

9. Livrables et conditions

9.1 Livrables

- Code source sur les dépôts du projet, avec un README complet et un `.env.example` à jour.
- `docs/schema-reel.md` documentant les écarts constatés au chantier C0.
- Migrations versionnées reproduisant le schéma depuis une base vide.
- Suite de tests et chaîne d'intégration continue fonctionnelle.
- Procédure de remise en service d'une tablette, rédigée pour un non-technicien.
- Procédure de restauration de la base, testée.
- Documentation d'exploitation : que faire quand une officine appelle, quand une tablette ne sonne plus, quand un patient conteste une réservation.

9.2 Conditions non négociables

- **Tous les comptes de service sont au nom d'Amadou Niang :** hébergement, SMS, Sentry, nom de domaine, et plus tard le paiement. Aucun compte au nom du développeur, même temporairement.
- Les dépôts appartiennent à l'organisation du projet, pas à un compte personnel de développeur.
- Paiement par jalon, à la recette démontrée en production.
- Aucune officine réelle mise en production avant la fin du jalon A.
- Accord de confidentialité signé avant la remise de la version complète du cahier et de tout accès au code, à l'hébergement ou à la base.

9.3 Inconnues assumées

- Le schéma réel de production n'est pas connu. C0 peut révéler des écarts qui augmentent son estimation de 3 jours : à signaler immédiatement, pas à absorber en silence.
- L'audit de sécurité de C1 peut révéler des corrections supplémentaires, signalées et chiffrées à part.
- Le calendrier des gardes n'a pas de source de données identifiée ; C9 prévoit l'import et la correction manuelle pour cela.

9.4 Réponse attendue

1. Un devis détaillé par chantier (C0 à C12) et par jalon, avec vos propres estimations en jours.
2. Un planning sur 8 semaines, ou votre contre-proposition argumentée.
3. Vos références sur un projet Node.js / PostgreSQL en production.
4. Vos questions sur le périmètre.